

PLANTILLA EXCEL: CÁLCULO IGM Y ANÁLISIS ROI

Implementación para Análisis Automático de Respuestas

Versión: 2.0 | **Formato:** Excel (.xlsx) | **Macros:** VBA opcional | **Compatibilidad:** Excel 2016+, Google Sheets

DESCRIPCIÓN GENERAL

Plantilla Excel automatizada que procesa respuestas de encuesta (75 preguntas, escala L1-L5) para generar:

1. **Índice Global de Madurez (IGM) %** con nivel CMM L0-L5
2. **Análisis por bloque** (10 bloques temáticos)
3. **Brecha normativa** vs. NIS2, ENS, ISO 27001
4. **Análisis ROI** de salvaguardas propuestas
5. **Dashboard ejecutivo** (gráficos, KPIs)

ESTRUCTURA HOJAS EXCEL

1. HOJA: "Datos Brutos" (Input)

Columnas:

- A: # Pregunta (P1.1.1, P1.1.2, etc.)
- B: Texto pregunta (corto, <50 car)
- C: Bloque (1-10)
- D: Respondente 1 (puntuación 1-5 o vacío)
- E: Respondente 2 (puntuación 1-5)
- F: Respondente 3 (puntuación 1-5)
- G: Media respondentes (fórmula = AVERAGE(D:F), validar 1-5)
- H: Observación (comentario cualitativo)

Filas: 75 preguntas + header

Fórmulas:

```
G2: =IF(COUNT(D2:F2)>0, AVERAGE(D2:F2), "")
```

Validación de datos:

- Columnas D-F: Autorizar solo 1-5 o vacío
- Mostrar advertencia si >5 o <1

2. HOJA: "Análisis IGM"

Estructura:

Sección A: IGM General

Métrica	Fórmula	Valor
IGM (%)	=AVERAGE('Datos Brutos'!G2:G76)*20	62
Nivel CMM	=IF(IGM_Pct<20,"L1",IF(IGM_Pct<40,"L2",IF(IGM_Pct<60,"L3",IF(IGM_Pct<80,"L4","L5"))))	L3
Target 12m (%)	Manual input	75
Gap (%)	=Target12m - IGM_Pct	13
Descripción Nivel	Tabla lookup	Repetible (procesos documentados)

Sección B: Análisis por Bloque

Bloque	# Preg	Puntuación Media	IGM Bloque (%)	Peso (%)	Contribución	Estado
1. Gobernanza	4	3,2	64	15%	9,6	● Aceptable
2. MAGERIT MAR	8	2,8	56	20%	11,2	● Bajo
3. Métricas	7	3,4	68	10%	6,8	● Bueno
4. Vulnerabilidades	9	3,1	62	12%	7,4	● Aceptable
5. SIEM	12	2,9	58	12%	7,0	● Aceptable
6. Capacitación	9	3,3	66	8%	5,3	● Aceptable
7. Resiliencia	10	2,5	50	10%	5,0	● Bajo
8. Cumplimiento	10	3,0	60	8%	4,8	● Aceptable
9. Incidentes	6	2,7	54	3%	1,6	● Bajo
10. Madurez General	1	3,0	60	2%	1,2	● Aceptable
TOTAL IGM	75	3,1	62	100%	62	L3

Fórmulas:

Puntuación Media Bloque = AVERAGE(preguntas bloque)
IGM Bloque (%) = (Puntuación Media × 20)
Contribución = IGM Bloque × Peso
Estado = IF(IGM Bloque < 40, "🔴 Bajo", IF(IGM Bloque < 60, "🟡 Aceptable", "🟢 Bueno"))

Sección C: Fortalezas y Debilidades

Top 3 Fortalezas:

1. Bloque 3 (Métricas): 68% – "Empresa mide bien KPIs"
2. Bloque 1 (Gobernanza): 64% – "Políticas documentadas"
3. Bloque 6 (Capacitación): 66% – "Formación regular"

Top 3 Debilidades:

1. Bloque 7 (Resiliencia): 50% – "RTO/RPO sin testar"
2. Bloque 2 (MAR): 56% – "Análisis riesgos ad hoc"
3. Bloque 9 (Incidentes): 54% – "CSIRT sin 24/7"

Asimetrías NIST (Desequilibrio):

- Identify: 68% / Protect: 63% / Detect: 64% / Respond: 55% / Recover: 50%
- Debilidad crítica: Respond + Recover (NIS2 requiere <72h)"

3. HOJA: "Brecha Normativa"

Mapeo pregunta – Requisito NIS2/ENS/ISO

Requisito	Preguntas Encuesta	Media Respuestas	L3+ (%)	Conformidad (%)	Riesgo	Acción Recomendada
NIS2 Art 21(a) Análisis Riesgos	P2.1-2.4	2,8	4/8 (50%)	50%	MODERADO	Plan 90 días, invertir PILAR MAGERIT
NIS2 Art 21(h) Continuidad	P7.1-7.4	2,5	2/10 (20%)	20%	CRÍTICO	Urgente: RTO/RPO formalizar + testing
NIS2 Art 21(g) Incidentes	P9.1, P8.3.1	2,7	1/3 (33%)	33%	CRÍTICO	SOC 24/7, notificación <72h
ENS Op.pl.1 Análisis Riesgos	P2.1-2.4	2,8	4/8 (50%)	50%	MODERADO	Idem NIS2
ISO 27001 A.12 Gestión Riesgos	P2.1-2.4, P3.1-3.3	3,0	9/15 (60%)	60%	MODERADO	Certificación ISO viable con mejoras 6m
NIST CSF Respond	P9.1-9.3	2,7	2/6 (33%)	33%	CRÍTICO	Playbooks SOAR, training operadores

Cálculos:

Conformidad (%) = (# preguntas L3+ / Total preguntas requisito) × 100

Riesgo = IF(Conformidad < 20%, "CRÍTICO", IF(Conformidad < 50%, "MODERADO", "BAJO"))

Color-coding:

- Rojo (<50%): Riesgo incumplimiento, acción inmediata
- Amarillo (50-80%): Moderado, plan 90 días
- Verde (>80%): Aceptable, mantenimiento

4. HOJA: "ROI Salvaguardas"

Análisis financiero de inversiones ciberseguridad propuestas

#	Salvaguarda Propuesta	Bloque Origen	ALE Actual (€)	ALE post-Salvaguarda (€)	ALE Reducción (€)	Costo Impl (€)	Costo/año Manto (€)	Payback (meses)	ROI 3yr (%)	Prioridad
1	Implementar SIEM	5	180.000	45.000	135.000	50.000	25.000	3,7	710%	CRÍTICA
2	Formalizar RTO/RPO + Testing	7	200.000	60.000	140.000	75.000	30.000	3,2	560%	CRÍTICA
3	SOC 24/7 (MSSP)	9	150.000	80.000	70.000	120.000	180.000	20,6	75%	IMPORTANTE
4	Formación avanzada empleados	6	100.000	75.000	25.000	20.000	15.000	8,0	225%	IMPORTANTE
5	Auditoría externa ISO 27001	8	0	0	0	35.000	10.000	N/A	Conformidad	REGULATORIO

Fórmulas FAIR/ALE:

ALE Actual (€) = TEF * LM

Donde:

TEF (Threat Event Freq) = Histórico incidentes / año × (1 - Control Strength Actual)

LM (Loss Magnitude) = Primary + Secondary Loss

ALE Reducción = ALE Actual - ALE post-Salvaguarda

Payback (meses) = Costo Implementation / (ALE Reducción / 12)

ROI 3yr (%) = [(ALE Reducción × 3) - (Costo Impl + Costo/año Manto × 3)] / Costo Impl × 100

Ejemplo SIEM:

- TEF (ataques detallados hoy): 4/año (de histórico)
- Control Strength actual (sin SIEM): 15% detección = $LEF = 4 \times (1 - 0.15) = 3,4/\text{año}$
- Primary Loss (análisis forense, cleanup): €40K
- Secondary Loss (multa NIS2 2%, reputación): €100K
- LM = €140K
- ALE Actual = $3,4 \times 140K = €476K$
- Con SIEM (detección 80%): $LEF = 4 \times (1 - 0.80) = 0,8/\text{año}$
- ALE post-Salvaguarda = $0,8 \times 140K = €112K$
- ALE Reducción = $€476K - €112K = €364K/\text{año}$
- Costo SIEM: \$50K implementación + \$25K/año mantenimiento
- Payback: $€50K / (€364K/12) = 1,6 \text{ meses}$
- ROI 3yr: $(€364K \times 3 - €50K - €75K) / €50K = 2.047\%$ (excelente)

Priorización:

- Ordenar por Payback (menor primero) o ROI 3yr (mayor primero)
- Filtrar por "Prioridad Crítica" para presupuestos limitados

5. HOJA: "KPIs Ejecutivos"

Dashboard resumen para Junta Directiva (1 página impresa)

ESTADO CIBERSEGURIDAD ENERO 2026 Evaluación: Madurez Integral

IGM GLOBAL

62% (L3 Repetible)

Target 2026: 75%

Gap: 13 puntos



¡Acciones iniciadas!

MADUREZ POR FUNCIÓN NIST

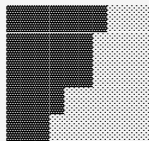
Identify: 68%

Protect: 63%

Detect: 64%

Respond: 55%

Recover: 50%



✓ Bueno

✓ Aceptable

✓ Aceptable

⚠ Débil (NIS2!)

● Crítico

BRECHA NORMATIVA

NIS2 Análisis Riesgos: 50% ⚠ Moderado

NIS2 Continuidad (RTO/RPO): 20% ● Crítico

NIS2 Incidentes (72h): 33% ● Crítico

ENS Cumplimiento: 65% ✓ Aceptable

ISO 27001 Alineación: 60% ✓ Aceptable

RIESGO RESIDUAL

ALE Anual (Con salvaguardas actuales):
€840.000/año (MODERADO)

Con plan de acción propuesto:
€480.000/año (Reducción 43% en 12m)
Inversión requerida: €280.000
ROI esperado: 180% (Payback: 4 meses)

TOP 5 ACCIONES INMEDIATAS

1. [CRÍTICO] Formalizar RTO/RPO + Testing
Presupuesto: €75K | Plazo: 3 meses

2. [CRÍTICO] Implementar SIEM
Presupuesto: €50K | Plazo: 6 meses

3. [CRÍTICO] SOC 24/7 operacional
Presupuesto: €120K/año | Plazo: 2 meses

4. [MODERADO] MAGERIT MAR formalizar
Presupuesto: €30K | Plazo: 3 meses

5. [MODERADO] Formación avanzada
Presupuesto: €20K | Plazo: 6 meses

TOTAL INVERSIÓN: €295K | ROI ESPERADO: 180%

Informe completo: [\[enlace\]](#)

Gráficos recomendados (inserts):

1. **Gauge IGM:** 62% con zonas (L1-L5)
2. **Radar NIST:** 5 ejes (Identify-Recover) con línea actual + target
3. **Heatmap Brecha:** 8 requisitos × % conformidad (verde/amarillo/rojo)
4. **Bubble ROI:** X=Costo, Y=ALE Reducción, tamaño=plazo

6. HOJA: "Referencias y Validación"

Tablas lookup y constantes:

Tabla L1-L5 Interpretación:

L1	Inicial	Ad hoc, sin proceso, reaccionario
L2	Básico	Documentado, inconsistente aplicación
L3	Repetible	Procedimientos formales, consistente
L4	Gestionado	Medido, monitoreado, mejora continua
L5	Optimizado	Automatizado, predictivo, benchmarking

Tabla Conversión Puntuación → %:

- 1 → 0-20%
- 2 → 21-40%
- 3 → 41-60%
- 4 → 61-80%
- 5 → 81-100%

Tabla Colores Riesgo:

Rojo (#FF0000): Riesgo CRÍTICO (acción inmediata)
Amarillo (#FFFF00): Riesgo MODERADO (plan 90 días)
Verde (#00AA00): Riesgo BAJO (mantenimiento)

Tabla Requisitos NIS2:

Art 17	Gobernanza	Requisito Base
Art 21(a)	Análisis Riesgos	Crítico
Art 21(g)	Gestión Incidentes	Crítico (72h)
Art 21(h)	Continuidad	Crítico (RTO/RPO)
Art 21(i)	Formación	Importante

INSTRUCCIONES DE USO

Paso 1: Importar Respuestas

1. Copiar respuestas encuesta digital (Google Forms export)
2. Pegar en hoja "Datos Brutos" columnas D-F
3. Validar que Media (columna G) se calcula automáticamente

Paso 2: Generar Análisis

4. Abrir hoja "Análisis IGM"
5. Verificar que IGM (%), CMM Level, Brecha Normativa se actualizan
6. Revisar Top 3 Fortalezas/Debilidades (autocarados desde datos)

Paso 3: Evaluar ROI

7. Ir a hoja "ROI Salvaguardas"
8. Completar columnas ALE (usando histórico + benchmark FAIR)
9. Ordenar por Payback (menor primero)
10. Seleccionar top 5-10 salvaguardas para plan acción

Paso 4: Informe Ejecutivo

11. Imprimir hoja "KPIs Ejecutivos" (1 página)
12. Exportar gráficos (IGM, Radar, Heatmap) para PowerPoint
13. Añadir a documento informe ejecutivo (06-template-reporte-ppt.md)

NOTAS TÉCNICAS

Compatibilidad:

- Excel 2016 en adelante: ✓ Sí
- Google Sheets: ✓ Sí (sin macros avanzadas)
- Números (Mac): ⚠ Parcial (validaciones pueden no funcionar)

Macros VBA (opcional, para automatización avanzada):

```
' Macro: Auto-generar colores brecha normativa
Sub ColorearBrechaNormativa()
  For Each cell In Range("E:E")
    If cell.Value < 0.5 Then
      cell.Interior.Color = RGB(255, 0, 0) ' Rojo
    ElseIf cell.Value < 0.8 Then
      cell.Interior.Color = RGB(255, 255, 0) ' Amarillo
    Else
      cell.Interior.Color = RGB(0, 170, 0) ' Verde
    End If
  Next cell
End Sub
```

DESCARGA Y DISTRIBUCIÓN

Archivo: 05-template-gim-roi.xlsx

Tamaño: ~2 MB (con gráficos embebidos)

Fórmulas: Protegidas (solo editar secciones de datos indicadas)

© 2026 Plantilla Excel IGM+ROI Kit MAGERIT-NIS2-ENS | Consorcio Ciberseguridad

Hoja de cálculo funcional para análisis automático. Requiere Excel 2016+ o Google Sheets.